

Security+ 3.3 · Data Types & Classifications

Mestre CyberSec · Aula 3.3 — Data Types & Classifications (5:54) · [Assistir Vídeo no YouTube](#) ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Classificar o dado: PUBLIC (nada perde); INTERNAL (apenas dentro); CONFIDENTIAL (estratégia, PII — fuga = dano grave); RESTRICTED (trade secret — fuga=catastrófico). A classificação DETERMINA o controle. PHI=dado de saúde; PCI-DSS=cartão.

💡 Highlights que a prova CompTIA cobra

- Classificação determina QUAL proteção cada dado recebe
- PHI = saúde; PCI-DSS = cartão; PII = dados pessoais

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'least restrictive classification'=public; 'most restrictive'=restricted

Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 3.3 — Data Types & Classifications)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Dados Públicos (N/A)

Informação aprovada para divulgação a qualquer pessoa, sem expectativa de confidencialidade; a divulgação não causa dano.

 **Armadilha CompTIA:** Gatilho: 'least restrictive classification' = Public. Se puder ser compartilhado livremente, é Public.

• Dados Internos (N/A)

Informação destinada apenas ao uso interno da organização; a divulgação não autorizada pode causar dano operacional ou reputacional limitado.

 **Armadilha CompTIA:** Gatilho: uso apenas dentro da empresa, nem público nem altamente sensível. Não confundir com Public.

• Dados Confidenciais (N/A)

Informação sensível como estratégia de negócio ou PII; a divulgação não autorizada pode causar dano grave à organização ou a indivíduos.

 **Armadilha CompTIA:** Gatilho: PII, estratégia, planos internos = Confidential. Fuga gera dano grave.

• Dados Restritos (N/A)

Classificação mais sensível, incluindo segredos comerciais; a divulgação não autorizada causa dano catastrófico e exige os controles mais rígidos.

 **Armadilha CompTIA:** Gatilho: 'most restrictive classification' = Restricted. Trade secret/fuga catastrófica = Restricted.

• Informações de Identificação Pessoal (PII)

Dados que podem identificar um indivíduo específico, como nome, CPF/SSN ou biometria; geralmente classificados como Confidential e protegidos por leis de privacidade.

 **Armadilha CompTIA:** Gatilho: PII = dados pessoais; se vazar, geralmente é Confidential com dano grave.

• Informações de Saúde Protegidas (PHI)

Informação de saúde que identifica um indivíduo e é protegida por regulamentações como HIPAA; exige controles rigorosos de privacidade e segurança.

 **Armadilha CompTIA:** Gatilho: PHI = dado de saúde. Se a questão citar HIPAA ou prontuário, pense PHI.

• Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI-DSS)

Padrão de segurança para organizações que armazenam, processam ou transmitem dados de cartão; a não conformidade pode gerar multas e perda de processamento de pagamentos.

 **Armadilha CompTIA:** Gatilho: PCI-DSS = cartão/cardholder data. Não é uma classificação, é um padrão de compliance.

• Classificação de Dados (N/A)

Processo de rotular dados com base na sensibilidade e valor para que controles de segurança e procedimentos de manuseio apropriados sejam aplicados.

 **Armadilha CompTIA:** Gatilho: a classificação DETERMINA o controle. Primeiro classifique, depois aplique proteção proporcional.

Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um hospital armazena nomes de pacientes, diagnósticos, históricos de medicação e identificadores de seguro em um sistema de prontuários clínicos. A equipe de segurança deve documentar o tipo de dado regulamentado representado por esse conjunto. Qual tipo de dado é?

- A) Dados públicos
- B) Informações de identificação pessoal (PII)
- C) Informações de saúde protegidas (PHI)
- D) Dados de cartão de pagamento

QUESTÃO 2 · CENÁRIO DE EXAME

Um sistema de RH contém números de Seguro Social, endereços residenciais, datas de nascimento e detalhes de contato de emergência de funcionários. Qual tipo de dado é representado?

- A) Dados públicos
- B) Informações de identificação pessoal (PII)
- C) Informações de saúde protegidas (PHI)
- D) Dados de cartão de pagamento

QUESTÃO 3 · CENÁRIO DE EXAME

Um aplicativo de pagamento de varejo processa números de conta principal, datas de validade e códigos de serviço de clientes durante o checkout. Qual tipo de dado regulamentado se aplica a essas informações?

- A) Informações de identificação pessoal (PII)
- B) Informações de saúde protegidas (PHI)
- C) Dados do Payment Card Industry Data Security Standard (PCI-DSS)
- D) Dados públicos

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa publica seu relatório anual de sustentabilidade em um site acessível externamente para que qualquer pessoa possa baixá-lo sem autenticação. Sob uma política de quatro níveis: Público, Interno, Confidencial e Restrito, como esse relatório deve ser classificado?

- A) Público
- B) Interno
- C) Confidencial
- D) Restrito

QUESTÃO 5 · CENÁRIO DE EXAME

Um diretório de nomes de funcionários e ramais de trabalho é acessível apenas pela rede corporativa e não é compartilhado com clientes, fornecedores ou o público. Como esse diretório deve ser classificado sob uma política de quatro níveis: Público, Interno, Confidencial e Restrito?

- A) Público
- B) Interno
- C) Confidencial
- D) Restrito

QUESTÃO 6 · CENÁRIO DE EXAME

Um banco de dados de marketing contém nomes de clientes, endereços de e-mail, históricos de pedidos e números de contas de fidelidade. A divulgação não autorizada causaria dano reputacional e regulatório grave à empresa. Sob uma política de quatro níveis: Público, Interno, Confidencial e Restrito, como esse banco de dados deve ser classificado?

- A) Público
- B) Interno
- C) Confidencial
- D) Restrito

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa de tecnologia armazena código-fonte e documentos de design de um produto não lançado que usa algoritmos proprietários. A divulgação daria grande vantagem a concorrentes e causaria perda financeira catastrófica. Sob uma política de quatro níveis: Público, Interno, Confidencial e Restrito, como esse material deve ser classificado?

- A) Público
- B) Interno
- C) Confidencial
- D) Restrito

QUESTÃO 8 · CENÁRIO DE EXAME

Um funcionário precisa compartilhar um memorando com um consultor externo. O memorando está atualmente rotulado apenas para uso interno e não contém PII, PHI, dados de cartão de pagamento ou segredos comerciais. De acordo com o tratamento orientado pela classificação, o que o funcionário deve fazer primeiro?

- A) Enviá-lo ao site público e mandar a URL ao consultor
- B) Criptografá-lo com uma senha pessoal e enviá-lo de uma conta de e-mail pessoal
- C) Solicitar uma exceção de política ou reclassificação antes de compartilhá-lo externamente
- D) Publicá-lo no site de colaboração interna e dar ao consultor uma conta VPN

QUESTÃO 9 · CENÁRIO DE EXAME

Um hospital precisa enviar informações de saúde protegidas a um fornecedor de cobrança para processamento de sinistros. Qual conjunto de controles melhor se alinha à classificação e aos requisitos regulatórios do dado?

- A) Rotular os dados como públicos e publicá-los em um portal público para download pelo fornecedor
- B) Converter os dados em PDF e enviá-los por e-mail comum sem criptografia
- C) Usar transferência criptografada, acordo de associado de negócios, acesso de menor privilégio e registro de auditoria
- D) Armazenar os dados em um compartilhamento interno e dar ao fornecedor uma conta local compartilhada

QUESTÃO 10 · CENÁRIO DE EXAME

Um bucket de armazenamento em nuvem contém PDFs de marketing liberáveis publicamente, documentos de políticas internas e registros de contas de clientes com PII. A equipe de segurança deve aplicar a política de classificação de dados da empresa ao conteúdo do bucket. Qual abordagem é mais apropriada?

- A)** Rotular o bucket inteiro como público porque alguns arquivos são seguros para divulgação
- B)** Rotular o bucket inteiro como confidencial porque alguns arquivos contêm PII
- C)** Criptografar o bucket uma vez e dar acesso a todos os funcionários para simplificar o gerenciamento
- D)** Aplicar rótulos de classificação por objeto e impor controles de acesso e DLP com base em cada rótulo

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Informações de saúde protegidas (PHI)

Correto: PHI. O conjunto combina informações de saúde com identificadores, portanto são informações de saúde protegidas pela HIPAA. PII é um termo mais amplo para dados pessoais, mas não aborda especificamente informações de tratamento de saúde; dados públicos e dados de cartão de pagamento estão incorretos porque os registros não são compartilháveis abertamente nem dados de cartão.

Questão 2: Alternativa B — Informações de identificação pessoal (PII)

Correto: PII. Esses campos podem identificar um indivíduo específico e exigem proteção. PHI se aplica a informações de saúde, dados de cartão de pagamento se aplicam a dados de portadores de cartão, e dados públicos não exigiriam controles de privacidade.

Questão 3: Alternativa C — Dados do Payment Card Industry Data Security Standard (PCI-DSS)

Correto: dados PCI-DSS. Dados de portador de cartão, como PAN, data de validade e código de serviço, são regidos pelo PCI-DSS. PII e PHI são categorias regulamentadas diferentes, e dados públicos não têm esses requisitos de proteção.

Questão 4: Alternativa A — Público

Correto: Público. O dado destina-se à divulgação aberta e sua exposição não causa dano. Dados internos não são para divulgação externa, dados confidenciais causariam dano grave se expostos, e dados restritos causariam dano catastrófico.

Questão 5: Alternativa B — Interno

Correto: Interno. Ele apoia operações internas e deve permanecer dentro da organização, mas sua exposição não causaria dano grave ou catastrófico. Público permitiria divulgação aberta, enquanto Confidencial e Restrito exigem proteção mais forte.

Questão 6: Alternativa C — Confidencial

Correto: Confidencial. PII de clientes e dados relacionados a contas geralmente exigem proteção porque a exposição causa dano grave. Restrito é reservado para segredos comerciais ou dados cuja perda é catastrófica. Público e Interno não se aplicam porque os dados são sensíveis e não meramente informações operacionais internas.

Questão 7: Alternativa D — Restrito

Correto: Restrito. O material é um segredo comercial cuja exposição causaria dano catastrófico. Confidencial cobre dano grave, como exposição de PII, enquanto Interno e Público forneceria proteção muito inferior.

Questão 8: Alternativa C — Solicitar uma exceção de política ou reclassificação antes de compartilhá-lo externamente

Correto: Solicitar uma exceção de política ou reclassificação. Dados internos destinam-se ao uso interno, então o compartilhamento externo exige aprovação e possivelmente um novo rótulo com controles apropriados. Publicação pública é não autorizada, e-mail pessoal contorna a política, e dar acesso VPN a terceiro altera o acesso sem tratar a classificação.

Questão 9: Alternativa C — Usar transferência criptografada, acordo de associado de negócios, acesso de menor privilégio e registro de auditoria

Correto: Usar transferência criptografada, BAA, acesso de menor privilégio e registro de auditoria. PHI é regulamentada e altamente sensível, portanto exige fortes salvaguardas técnicas e administrativas. Publicação pública, e-mail não criptografado e contas locais compartilhadas expõem os dados e violam expectativas da HIPAA.

Questão 10: Alternativa D — Aplicar rótulos de classificação por objeto e impor controles de acesso e DLP com base em cada rótulo

Correto: Aplicar rótulos de classificação por objeto e impor controles com base em cada rótulo. Um bucket misto não pode ser gerenciado com segurança com uma única classificação genérica. A rotulagem por objeto garante que dados públicos, internos e confidenciais recebam os controles apropriados de acesso, criptografia e monitoramento.